HANQIN LYU

Cloud Security Engineer | Azure Security · SC-500 · SC-200 · SC-300

+61 452 483 669 | lyuhanqin@gmail.com | Melbourne, VIC | LinkedIn | Portfolio

PROFESSIONAL SUMMARY

Azure Cloud Security Engineer holding SC-500 (Microsoft Certified: Cloud and AI Security Engineer Associate), SC-200 (Microsoft Security Operations Analyst), SC-300, and CompTIA Security+, with hands-on experience in cloud security, infrastructure-as-code security, and security automation. Built a closed-loop honeypot-to-Microsoft Sentinel SOC lab — four KQL detections mapped to MITRE ATT&CK and ten Logic Apps SOAR playbooks that enrich, block, contain and close incidents automatically, deployed and validated end to end as Terraform. Built shift-left pipelines and preventive guardrails using Terraform, GitHub Actions, Checkov, Azure Policy, and PowerShell/Python scripting. Clear written and verbal communication across APAC enterprise clients. Bilingual (English/Mandarin).

Core Competencies: SIEM & KQL (Microsoft Sentinel) | Cloud Security (Azure/AWS) | DevSecOps & IaC Security (Terraform / Checkov / Azure Policy) | Security Automation (PowerShell/Python) | Incident Response & Runbooks | Identity & Access Governance | Compliance (PCI DSS / NIST / ISO 27001) | Bilingual Communication (English/Mandarin)

WORK EXPERIENCE & PROJECT

QSA Associate (Internship) | Stratica

July 2025 – December 2025

Corporate advisory firm specialising in cloud risk, PCI DSS compliance, and strategic sourcing

- **IAM & Compliance Review**: Reviewed IAM policies, Entra ID conditional access configurations, and AWS access controls across cloud-hosted environments to verify PCI DSS compliance — identifying privilege misconfigurations and recommending least-privilege remediation steps
- **Client Technical Communication**: Delivered clear written and verbal updates to enterprise clients across APAC, translating complex technical findings into actionable remediation steps
- **Documentation & Access Reporting**: Prepared Attestations of Compliance (AOC), assessment reports, and bilingual (English/Mandarin) client materials
- **Stakeholder Collaboration**: Coordinated with senior consultants and client teams to track open issues, verify resolution, and maintain audit trails

Cloud Infrastructure Specialist (Project) | Melbourne Polytechnic

July 2024 – November 2024

AWS Network Environment Deployment — Academic Capstone

- **Infrastructure Deployment**: Architected and deployed a multi-tier AWS VPC with cross-AZ redundancy and auto-scaling, applying CIS AWS Foundations Benchmark controls
- **IAM & Access Control**: Designed and enforced IAM roles, SCPs, and least-privilege access policies across a multi-tier AWS environment; implemented RBAC and conditional access controls aligned with Zero Trust principles; configured VPN and Direct Connect for secure hybrid identity connectivity
- **Incident Simulation & Remediation**: Identified and remediated vulnerabilities through structured assessments; automated response workflows with Python/PowerShell

Network Technician (Project) | Melbourne Polytechnic

April 2024 – June 2024

Network Security Infrastructure Configuration

- **Network Design**: Deployed Cisco multilayer infrastructure with OSPF routing across 3 sites
- **Security Hardening**: Configured zone-based firewalls, micro-segmentation, Cisco IPS/IDS, and WPA3-Enterprise wireless with RADIUS authentication
- **Troubleshooting & Testing**: Conducted penetration testing and validated end-to-end security controls

Identity Governance Engineer (Personal Project) | Self-Directed *Jun 2026 – Jul 2026*

Zero Trust identity governance architecture on Microsoft Entra ID, aligned to the SC-300 skills framework

- **Zero-Secret Identity Architecture**: Implemented Workload Identity Federation (OIDC) and Managed Identity for GitHub Actions and Azure Automation, eliminating long-lived client secrets across CI/CD and native Azure workloads
- **Privileged & Risk-Adaptive Access**: Converted high-privilege directory and Azure resource roles (Global Administrator, Key Vault, Automation Account) to time-bound PIM Eligible assignments; designed 6 layered Conditional Access policies enforcing phishing-resistant MFA for privileged roles and risk-based response for standard users
- **Identity Lifecycle Automation**: Built Entitlement Management access packages (time-bound and recurring-review models) and full Joiner-Mover-Leaver Lifecycle Workflows automating onboarding, department transfers, and offboarding with token revocation

Cloud Security Engineer (Personal Project) | Self-Directed *Sep 2026 – Nov 2026*

Shift-left DevSecOps pipeline and subscription-level Azure Policy guardrails for an Azure workload, aligned to the SC-500 skills framework

- **Infrastructure as Code & Pipeline**: Defined an Azure workload (SQL, Key Vault, immutable-retention storage, AI Services, VNet/NSG) from 6 Azure Verified Modules in Terraform (36 managed resources), deployed only through GitHub Actions with Entra-authenticated remote state (no shared keys)
- **Shift-Left Security Gates**: Built 3 pull-request gates (fmt/validate, Checkov, gitleaks) that must pass before plan; caught 2 of 2 deliberately seeded misconfigurations (open SSH, hardcoded SQL password) and fixed a scanner blind spot that reported zero findings on AVM modules (8 failed checks, triaged to 4 with documented reasons)
- **Least-Privilege Delivery**: Split CI (Reader) and CD (Contributor) over GitHub OIDC with 0 stored client secrets; gated production apply behind a GitHub Environment with a required reviewer; CD identity cannot modify Azure Policy
- **Preventive Guardrails**: Authored a custom Azure Policy denying inbound SSH from any source, rolled out Audit-then-Deny at subscription scope; the same code deployed under Audit and was rejected with 403 RequestDisallowedByPolicy after CI gates were bypassed
- **AI-Assisted Engineering Governance**: Used Claude Code under a CLAUDE.md contract and 9 permission deny rules (no apply/destroy, no az login, no state reads), with no standing Azure credentials for the agent

SOC Detection & Response Engineer (Personal Project) | Self-Directed *Oct 2026 – Nov 2026*

Closed-loop SOC on Microsoft Sentinel — honeypot telemetry to automated detection and response, aligned to the SC-200 skills framework

- **Detection Engineering (KQL & MITRE ATT&CK)**: Authored 4 scheduled Sentinel analytics rules, one per response priority (P1–P4), mapped to MITRE ATT&CK (T1110 Brute Force, T1078/T1021 Valid Accounts, T1548 Elevation Abuse); diagnosed and fixed an ingestion-time windowing bug where an event-time filter ran before syslog landed and missed short attacks
- **SOAR Automation (10 Playbooks)**: Built 10 single-job Logic Apps playbooks and 3 automation rules covering the full response chain — enrich, notify, block, contain and close; automatic playbooks perform only safe, reversible steps (an auto-expiring 24-hour NSG block logged to a custom table), while disruptive steps (end session, lock account via Azure Run Command) are manual and analyst-triggered
- **Least-Privilege & Honeypot Isolation**: Granted each playbook managed identity a single built-in role at the smallest scope (one NSG rule, one VM, one Key Vault); the honeypot VM identity holds no roles and exposes only port 22, with every RBAC assignment defined in Terraform
- **Secret-Free IaC Delivery**: Deployed the lab as one Terraform root (Azure Verified Modules) through the same GitHub OIDC CI/CD pipeline (fmt/validate, Checkov, gitleaks, plan, then a human-approved apply); stored the AbuseIPDB key and Slack webhook in Key Vault, read at runtime by managed identity so no

secret touches the repo or state

- **End-to-End Validation**: Verified the full loop on real honeypot telemetry using KQL over SecurityIncident, Syslog and SOARBlocks_CL; documented honest engineering findings — a non-persisting incident label in Defender-integrated Sentinel (priority carried by severity instead), a portal "missing permissions" false positive, and a duplicate-incident merge artifact

EDUCATION & CERTIFICATIONS

Certificate IV in Cybersecurity | Melbourne Polytechnic

Master of Civil Engineering | Monash University

Professional Certifications:

- CompTIA Security+ — Network security, threat management, cryptography, risk management
- Microsoft SC-900 — Security, compliance, and identity fundamentals
- SC-300: Microsoft Identity and Access Administrator — Identity governance, Entra ID, conditional access, privileged identity management
- SC-500: Microsoft Certified: Cloud and AI Security Engineer Associate — End-to-end Azure security, Defender for Cloud, Sentinel, AI workload security, network and storage security
- SC-200: Microsoft Security Operations Analyst Associate — Sentinel, Defender XDR, KQL, hunting

TECHNICAL SKILLS

Cloud Platforms & Services:

- AWS: VPC, EC2, IAM, Security Groups, NACLs, CloudWatch, Auto Scaling, Load Balancing, Direct Connect
- Azure: Entra ID (Azure AD), Conditional Access, Privileged Identity Management (PIM), Identity Governance & Lifecycle, App Registrations, SSPR, SAML / OAuth 2.0 / OIDC / SCIM, Azure Sentinel, Microsoft Defender for Cloud, Azure Policy, Azure Verified Modules

Monitoring, Networking & Security:

- SIEM/Monitoring: Azure Sentinel, CloudWatch, Wireshark
- Networking: Firewalls, IDS/IPS, VPN (IPsec/AES-256), OSPF, WPA3, RADIUS, DNS, DHCP
- Compliance & Frameworks: PCI DSS, ISO 27001, NIST 800-53, CIS Controls, SOC 2, OWASP Top 10

Scripting & Tools:

- Python, PowerShell, Bash — security automation, access provisioning scripts, incident response
- IaC & DevSecOps: Terraform, Bicep, GitHub Actions (OIDC), Checkov, gitleaks, Claude Code
- OS: Windows, Linux, MacOS | Version Control: Git/GitHub | Languages: English, Mandarin (native)